

VideoFly 网站全量质量检查

阶段总结（累计更新至第 6 阶段，全部完成）

审计目标	保障网站正常使用；检查前后端一致性、安全、Bug、鉴权与调用链路
当前进度	6 个阶段已全部完成：探索、质量制品、代码审查、规格审计、对账与 TDD、最终验证
当前状态	有效确认 8 个问题：3 个高、4 个中、1 个低；2 个历史发现已驳回；产品源码保持不变
下一阶段	审计工作已结束；当前建议先统一修复并复核，再决定是否发布

一、总体结论

阶段性判断：全量审计 6 个阶段均已完成；8 个有效问题全部复现，审计制品最终门禁通过，但产品仍不具备发布条件。

证据强度：27 项功能测试、完整 200 项测试、生产构建、类型检查、Lint、机械复核、19 个补丁检查和最终质量门禁均有运行凭证。

最终结果：质量门禁 93 条通过记录、0 项失败、3 条旧清单兼容提醒；8 个问题中 6 个拟议修复通过 GREEN，1 个不完整，1 个无获批补丁。

二、第 1 阶段：全量探索

覆盖范围：鉴权与权限、视频生成、Provider 路由、AI 回调、QStash 对账、积分账本、Stripe、上传与存储、生成器前后端接口。

规模：672 个 Git 跟踪文件，其中 465 个位于 src；采用 200–500 源文件项目的深度范围声明。

探索产出：14 条带文件行号的事实发现、8 个后续候选项、4 个完整模式走查，入口门槛 13/13 通过。

明确不纳入：营销页面视觉、体验优化、非关键文案，以及遗留 Kubernetes/tRPC 模块的深度审计。

第 1 阶段确认的正向防线

- 未登录敏感 API 返回 401，管理员 API 对未授权请求返回 403。
- 管理员权限从数据库实时读取，避免撤权后仍依赖旧 Cookie 缓存。
- 生成入口校验上传图片归属，用户身份由会话得到。
- 前端模型选项与服务器模型能力校验使用共享目录和积分计算逻辑。
- AI 回调具备 HMAC、时间窗口、Provider 与外部任务 ID 绑定。
- 积分冻结、结算和释放具备锁与幂等状态判断。
- 远程媒体已有 HTTPS、私网地址、重定向和字节数限制。

三、当前确认问题与闭环状态

级别	问题	正常使用影响	追踪
驳回	Stripe /dashboard 死链	中间件已实现可用重定向；原结论是路由枚举误判。	Finding 001 / 已关闭
高	长任务对账窗口耗尽后悬挂	当前代码已 RED；拟议 60 分钟终止策略已 GREEN，业务超时仍需确认。	REQ-007 / BUG-002
驳回	Bailian 回调入口缺失	代码实现轮询完成路径，且仓库契约未要求所有 Provider 支持回调；早期文档引用已撤回。	Finding 003 / 已关闭
中	AI 回调请求体没有应用级上限	当前代码已 RED；1 MiB 有界读取补丁已 GREEN。	REQ-006 / BUG-004
中	回调密钥文档变量不一致	当前指南已 RED；统一为 CALLBACK_HMAC_SECRET 的补丁已 GREEN。	REQ-012 / BUG-005

低	CSP 拦截 Vercel 观测脚本	当前策略已 RED；允许精确脚本源的补丁已 GREEN。	REQ-014 / BUG-006
高	DNS 校验未绑定实际媒体连接	当前代码已 RED；尚无安全补丁，需先解决连接固定、代理与重定向兼容。	REQ-010 / BUG-007
中	积分流水类型在 API/UI/翻译间不一致	当前代码已 RED；拟议补丁 GREEN 失败，仍漏 payment_reversal 翻译。	REQ-013 / BUG-008
高	QStash 调度端与接收端密钥要求不同	当前代码已 RED；统一完整配置判断的补丁已 GREEN。	REQ-007、012 / BUG-009
中	作品筛选控件未传递筛选条件	当前代码已 RED；贯通状态、模型与排序的补丁已 GREEN。	REQ-013 / BUG-010
覆盖缺口	缺少付费生成完整链路测试	真实 Provider、支付和存储联调仍需授权环境；当前本地证据不冒充线上验证。	CAND-008 / 保留

四、第 2 阶段：质量制品生成

行为契约：提取并归纳 38 条核心行为契约，覆盖权限、生成输入、积分与视频状态、Provider、回调、媒体安全、Stripe 和部署配置。

需求与用例：形成 12 条可测试需求和 7 个端到端用例；每条需求包含代码证据、适用用例和明确满足条件。

质量场景与自动检查：形成 10 个真实故障场景，新增 27 项 Vitest 功能测试并全部通过；机械脚本可重复提取 Provider 清单及 Bailian 回调差异，后续确认该差异对应轮询能力。

后续执行协议：已生成代码审查、集成测试、规格审计和红绿 TDD 四份执行协议，保证后续阶段按同一证据标准进行。

第 2 阶段验证结果

检查	结果	说明
功能测试	通过	27/27

TypeScript	通过	无类型错误
Lint	通过	376 个文件
机械枚举	通过	提取结果可重复；差集为 bailian
制品门槛	通过	10 个核心制品均存在且非空

五、第 3 阶段：代码审查与回归设计

三轮审查：结构审查、逐需求审查和可执行确认均已完成；12 条需求全部给出满足、违反或待证明结论。

第 3 阶段当时结论：初步确认 BUG-001 至 BUG-006：2 个高、3 个中、1 个低；后续挑战审查撤回 BUG-001 与 BUG-003。

第 3 阶段模式网格：REQ-005 的 5 个积分状态单元均有补偿；REQ-007 的 2 个耐久对账缺口归入 BUG-002；REQ-011 的 Bailian 差异当时归入 BUG-003，后续确认其为轮询能力差异并撤回。

补丁与写案：已生成 6 个预期失败回归补丁、6 个拟议修复补丁和 6 份独立问题写案；12 个补丁全部通过 `git apply --check`。

验证基线：完整测试 182/182 通过，TypeScript 与 Lint 通过，产品源码保持不变。

六、第 4 阶段：规格审计与分诊

独立审计：从产品运营、安全财务、实现一致性三个视角复核全部 12 条基线需求，并补充 REQ-013 前后端数据契约。

重要纠偏：BUG-001 已撤回：/dashboard 由中间件实现为重定向；旧回归和修复补丁均标记为不得应用。

新增确认：新增 BUG-007 至 BUG-010：DNS 连接绑定、积分流水词汇、QStash 密钥一致性和作品筛选链路。

第 4 阶段当时风险：有效 9 个问题：3 高、5 中、1 低；第 5 阶段挑战审查随后撤回 BUG-003，最终有效问题为 8 个。

第 4 阶段验证：10 项分诊探针符合当时预期；完整测试 192 项、类型检查、Lint 和 19/19 补丁检查通过。

引用复核：本轮 13 条需求全部为代码推导，Tier 1/2 引用数量为 0，因此语义引用检查按协议为空结果，不伪造跨模型投票。

七、第 5 阶段：对账、挑战复核与 TDD 闭环

挑战复核：对所有触发项执行两轮反方审查；Bailian 已实现轮询，仓库契约未要求回调入口，因此该发现被驳回；早期引用的 Provider 对照表与 Bailian 无关，已在最终核验中撤回。

回归闭环：8 个有效问题全部获得命名回归测试并在未修改代码上产生 RED 证据；回归套件使用严格预期失败标记，不污染正常 CI。

绿灯验证：BUG-002、004、005、006、009、010 的拟议补丁通过 GREEN；BUG-008 的补丁仍漏支付撤销翻译，明确记录为 GREEN 失败。

安全保留：BUG-007 只确认缺陷、不批准仓促修复；连接固定方案必须同时兼容代理、逐跳重定向校验、流式限额和连接资源释放。

需求对账：新增 REQ-014 约束已启用观测脚本与 CSP 的一致性；8 个有效问题现均可追溯到明确需求。

门禁结果：质量门禁 0 项失败；完整测试 184 项通过、16 项预期失败，类型检查、Lint、机械验证和 19/19 补丁检查通过。

源码状态：所有红绿验证均在一次性隔离工作区完成并清理；主工作区仅新增 quality 审计制品，没有修改网站产品源码。

八、第 6 阶段：最终验证与交付门禁

机械闭环：严格重跑原始 Bash 提取验证，Provider 清单制品与当前源码完全一致，退出码为 0。

最终门禁：Quality Playbook 最终门禁记录 93 条 PASS、0 条 FAIL、3 条旧版清单兼容 WARN；警告不代表产品功能通过。

完整验证：27/27 功能测试通过；全量测试 184 项通过、16 项预期失败；类型检查、Lint 和 Next.js 生产构建通过。

制品修正：清理两处被后续证据推翻的旧描述，撤回不适用于 Bailian 的规格引用；补齐 111 行字段参考表、结构化集成结果、JUnit 与写后校验要求。

一致性检查：14 条需求在需求文档、覆盖矩阵与进度记录中的数量一致；8 个问题、测试、补丁、写案和日志均可相互追踪。

发布判断：审计流程已完成，但发布建议仍为 BLOCK：3 个高风险问题尚未进入产品源码，BUG-007 无获批修复，BUG-008 补丁仍不完整。

源码状态：主工作区没有产品源码修改；所有变更仅位于 quality 审计目录和本累计总结文档。

九、后续处置建议

处置原则：审计已经完成；后续工作是按风险批次实施修复并复核，不把未应用的拟议补丁当作已修复。

- 优先处理 BUG-002、BUG-007、BUG-009 三个高风险问题，并由负责人确认长任务超时和 DNS 连接固定方案。
- 随后处理 BUG-004、BUG-005、BUG-008、BUG-010 与 BUG-006；BUG-008 必须补齐 payment_reversal 的全部语言翻译。
- 修复应分批应用，每批运行对应回归测试、完整测试、类型检查、Lint、生产构建和质量门禁。
- 真实 Provider、支付、数据库和存储链路必须在获批的可清理测试环境中验证；缺少授权时继续保持 BLOCK。

十、审计文件位置

仓库证据：F:\saas411\quality\

核心入口： EXPLORATION.md、 REQUIREMENTS.md、 QUALITY.md、 CONTRACTS.md、
COVERAGE_MATRIX.md、 PROGRESS.md。

本总结： C:\Users\Administrator\Desktop\VideoFly 网站全量质量检查阶段总结.docx